

# Lista de Exercícios de Fixação – Questões Teóricas

---

## 1. Explique o que é JWT e quais são suas vantagens.

JWT (JSON Web Token) é um padrão de autenticação que permite transmitir informações de forma segura entre cliente e servidor através de um token.

Vantagens:

- Não requer armazenamento no servidor (stateless)
  - Fácil de usar em APIs
  - Pode ser usado em diferentes plataformas
  - Alto desempenho
- 

## 2. Qual a diferença entre sessões e cookies?

- **Sessões:** armazenam dados no servidor e utilizam um identificador para o cliente acessar essas informações.
- **Cookies:** armazenam dados diretamente no navegador do usuário.

Resumo: sessões são mais seguras (dados no servidor), enquanto cookies são armazenados no cliente.

---

## 3. Defina CORS e por que é importante configurá-lo corretamente.

CORS (Cross-Origin Resource Sharing) é um mecanismo que permite ou restringe requisições feitas entre diferentes origens (domínios).

É importante configurá-lo corretamente para:

- Evitar acessos não autorizados
  - Permitir integração segura entre sistemas
  - Proteger a aplicação contra ataques
- 

## 4. O que é CSRF e como prevenir este tipo de ataque?

CSRF (Cross-Site Request Forgery) é um ataque que força o usuário autenticado a executar ações indesejadas em uma aplicação.

Prevenção:

- Uso de tokens CSRF
- Validação de origem da requisição

- Uso de cookies seguros
- 

## 5. Explique o conceito de SQL Injection e seus riscos.

SQL Injection é um tipo de ataque onde comandos SQL maliciosos são inseridos em campos de entrada da aplicação.

Riscos:

- Acesso não autorizado ao banco de dados
  - Vazamento de informações
  - Alteração ou exclusão de dados
- 

## 6. Como o atributo HttpOnly ajuda a proteger cookies?

O atributo `HttpOnly` impede que os cookies sejam acessados via JavaScript no navegador.

Isso ajuda a proteger contra ataques como XSS (Cross-Site Scripting), evitando o roubo de cookies.

---

## 7. Quais são as principais partes de um token JWT?

Um JWT é composto por três partes:

- **Header (Cabeçalho):** informações sobre o tipo do token e algoritmo
  - **Payload:** dados armazenados (claims)
  - **Signature (Assinatura):** garante a integridade do token
- 

## 8. Liste três boas práticas para evitar SQL Injection em aplicações Node.js.

- Utilizar prepared statements
  - Validar e sanitizar entradas do usuário
  - Evitar concatenação direta de strings em queries
  - Utilizar ORM ou bibliotecas seguras
- 

## 9. O que é autenticação baseada em roles e quais são seus benefícios?

É um modelo onde o acesso é controlado com base no papel (role) do usuário, como admin, usuário comum, etc.

Benefícios:

- Controle de acesso mais organizado
- Maior segurança
- Facilidade de gerenciamento de permissões

---

## 10. Como o middleware csrf auxilia na proteção de aplicações web?

O middleware `csrf` gera e valida tokens únicos para cada requisição sensível.

Ele garante que a requisição foi realmente feita pelo usuário legítimo, protegendo contra ataques CSRF.

---